

NovaPay Payment Gateway — Technical Specification

Version 2.4 | Engineering Team | Confidential

1. System Overview

NovaPay is a PCI DSS Level 1 compliant payment processing gateway designed to handle up to 10,000 transactions per second with a target uptime SLA of 99.99%. The system is built on a microservices architecture deployed on Kubernetes across three geographic regions: US-East, EU-West, and AP-Southeast. All inter-service communication uses mTLS with certificate rotation every 24 hours.

2. Authentication & Authorization

API authentication uses OAuth 2.0 with JWT bearer tokens. Access tokens expire after 15 minutes; refresh tokens have a 30-day validity window. All merchant API keys are stored using AES-256 encryption at rest. Role-based access control (RBAC) defines three merchant tiers: Basic (1,000 TPS limit), Professional (5,000 TPS), and Enterprise (custom limits). Rate limiting is enforced at the API gateway layer using a sliding window algorithm.

3. Transaction Processing

Transactions are processed via a two-phase commit protocol. Phase 1 (Authorization) performs fraud scoring, card network communication, and fund reservation within a 3-second timeout. Phase 2 (Capture) settles the transaction and is triggered either immediately or via batch settlement at configurable intervals. Failed transactions are retried up to 3 times with exponential backoff starting at 500ms. The system supports 135 currencies and real-time FX conversion using rates updated every 60 seconds.

4. Data Retention & Compliance

Transaction records are retained for 7 years in compliance with PCI DSS requirements. Personally identifiable information (PII) is tokenized using format-preserving encryption (FPE) before storage. Full card numbers are never stored; only the last 4 digits and card network tokens are retained. Audit logs are written to an immutable S3 bucket with object lock enabled for a minimum retention of 90 days. GDPR data deletion requests are processed within 30 days.

5. Webhooks & Event System

All transaction lifecycle events are published to merchant webhook endpoints using HMAC-SHA256 signatures. Webhook delivery is guaranteed at-least-once with a maximum of 5 retry attempts over 24 hours. Merchants must respond with HTTP 200 within 10 seconds. Failed deliveries are queued in a dead-letter queue accessible via the merchant dashboard. Event types include: `payment.authorized`, `payment.captured`, `payment.failed`, `refund.created`, and `dispute.opened`.

6. Performance Requirements

The authorization endpoint must achieve p50 latency under 200ms and p99 latency under 800ms. The system auto-scales horizontally when CPU utilization exceeds 70% for 2 consecutive minutes.

Database read replicas handle all non-write queries; the primary write node uses synchronous replication to one standby. Circuit breakers trip when error rates exceed 5% over a 60-second window, failing fast to prevent cascade failures.